

Solution Sheet: Cybersecurity Fundamentals

Exercise 1

1.1 Explain in your own words the three protection goals that make up the C-I-A triad. Which two protection goals were added later on?

Three original protection goals:

- **Confidentiality** – Ensuring that data or information is not made available or disclosed to unauthorised persons or processes.
- **Integrity** – Guarding against improper information modification or destruction in an unauthorised and undetected manner.
- **Availability** – Ensuring timely and reliable access to and use of information (making information or services reliably accessible in time).

Two additional protection goals:

- **Authenticity** – Verifying that a user, process, or device is the one claimed, often as a prerequisite to allowing access to resources in an information system.
- **Non-Repudiation** - Assurance that the sender of data is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the data

1.2 How was risk mathematically defined in the lecture?

Risk (R_a) of an attack α is the product

$$R_a = p_a \times d_a$$

Where:

- p_a is the probability of attack α succeeding and
- d_a is the damage incurred by that attack if successful

1.3 Which questions are indicative of a security mindset?

- **Which parts do users have control over and which parts shouldn't they?**
- **What can this do outside of what it is meant to do?**
- **Is any of that unintended functionality useful?**

1.4 What are the three steps when creating an attack tree?

- **Create the tree, prune the tree, think of countermeasures**

1.5 What is the defining property of symmetric encryption, opposed to asymmetric encryption?

- **Both communication parties share the same key. (Symmetric encryption: Uses the same key for both encryption and decryption. Asymmetric encryption: Uses different keys for encryption and decryption—public/private key pairs).**

1.6 What are the three defining properties of cryptographic hash functions?

- **One-way function**
- **Collision resistant**
- **Efficient**

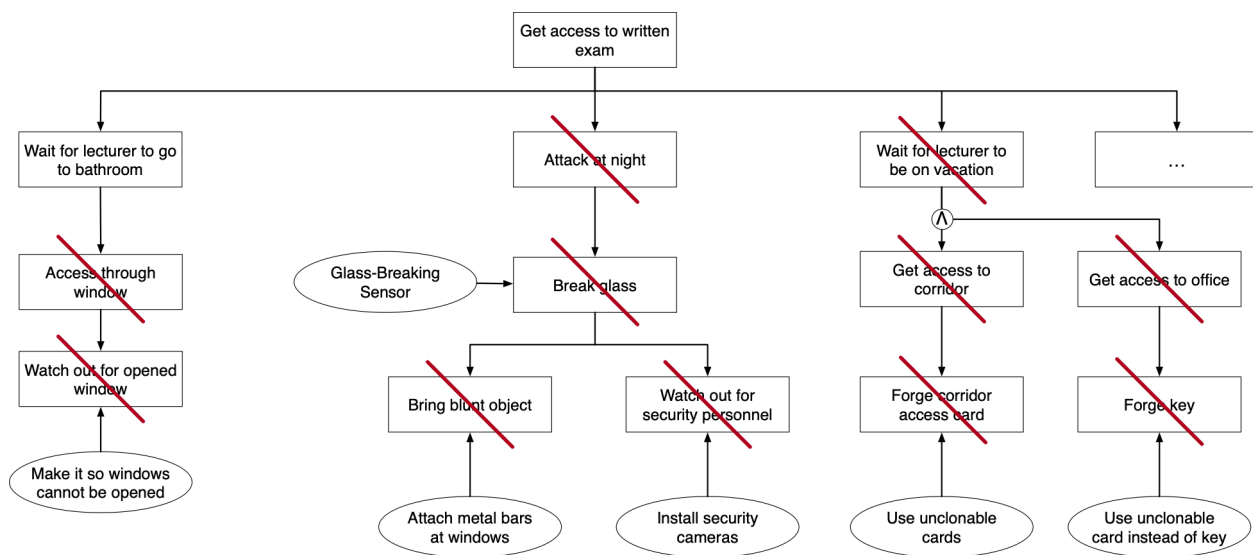
1.7 Briefly explain in your own words, the basic idea behind hybrid encryption.

- **Combining symmetric and asymmetric encryption.**

Exercise 2

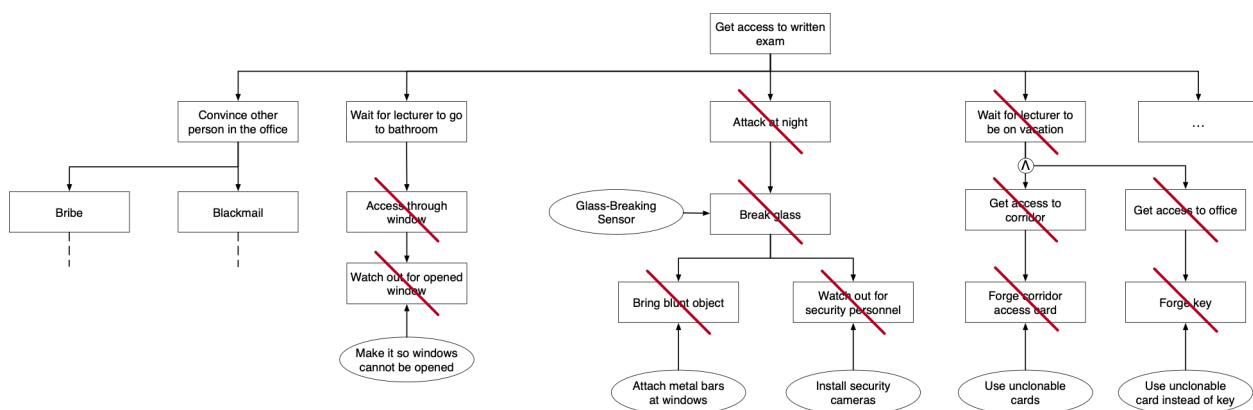
Assume your goal is to get hold of the written exam for a specific course. You know that the laptop of the respective lecturer is consistently unlocked when they go to the bathroom. However, their office is on a restricted corridor.

- 2.1 Draw an attack tree for this scenario. Consider all three steps of creating an attack tree separately and draw the tree in all three steps. You don't need a comprehensive tree, but make sure to have at least a few full paths with counter-measures.



As is obvious, there is no path giving us a successful attack, right?

- 2.2 How does the tree change, if the lecturer shares the office with another lecturer? Draw the tree again or add a respective sub-tree in this scenario.



Exercise 3

3.1 Explain the term Layered Security in your own words.

Countermeasures can fail. Therefore, redundancy in countermeasures important to have fallbacks. The Swiss Cheese Model gives us a way to understand this. Having multiple countermeasures in place one after the other (seen as layers of defense), this is called Layered Security.

Exercise 4

Assume a scenario like the “red telephone”, where two parties need to repeatedly communicate confidential information.

4.1 Which type of encryption is suitable for this scenario? Explain your answer.

With only two parties in the communication, symmetric encryption is the right choice. It is more efficient than asymmetric encryption and the key management is still easily handled. We should use a modern cryptographic standard such as AES. The One-Time-Pad is not suitable in this scenario. Due to the repeated communication of unknown length a constant flow of key material through another secured channel would be required in that case.

4.2 Assume the number of parties grows to five. Which type of encryption is suitable for this scenario? Explain your answer.

In this case, the key management starts to become a problem, therefore, hybrid encryption is the right choice. The added complexity of using the two types of encryption in combination is offset by the benefits in key management.

Exercise 5

5.1 What are the benefits of hybrid encryption?

It combines the efficiency of symmetric encryption with the easier key management of asymmetric encryption.

5.2 Can you imagine a scenario where this is used today? Give an example and explain why it makes sense in this case.

It is used in many scenarios, e.g., in HTTPS.

Exercise 6

6.1 Encrypt the bitstring $m = 10110110\ 01100111$ using with the key $k = 01010110\ 01011100$ using the One-Time-Pad algorithm. Assume bit-wise encryption.

1110000000111011